

План разработки и roadmap «Product Factory» для соло-разработчика, использующего агентов

Исполнительное резюме

Я отвечу как архитектор платформенной инженерии и безопасных агентных систем, специализирующийся на production-ready внутренних платформах, supply-chain security и AI-governance.

TL;DR: как соло-разработчик, я могу реалистично построить “Product Factory” за 6–12 месяцев, если начну с узкого MVP (один archetype, один golden path, жёсткие контракты tool-calling, политик-движок и наблюдаемость), а агентность буду расширять только после появления воспроизводимых quality gates (тесты + security + eval + бюджеты). Базовый принцип — разделить детерминированный **control plane** (оркестрация, политики, исполнение инструментов, аудит) и недетерминированный **intelligence plane** (LLM/агенты/RAG), чтобы агенты никогда не делали side-effects напрямую. ¹

Исходная цель «Product Factory» в предоставленных материалах сформулирована как построение автоматизированной платформы/сервиса, который **по запросу** создаёт **готовый deployable-артефакт**: репозиторий с кодом, тестами, IaC, CI/CD, наблюдаемостью и управляемыми AI-компонентами (агенты/LLM).

Ключевое требование для production-реальности — “управляемая агентность”: агенты генерируют планы/код/артефакты через **строгие контракты** (schema) и **политики**, а любые изменения реального мира (деплой, базы, секреты, биллинг) проходят через **policy enforcement**, песочницу и аудит. ²

Почему в 2026 это важно: требования к ответственности, безопасности и прозрачности растут одновременно с возможностями агенто-ориентированных систем. В ЕС действует **AI Act** (Regulation (EU) 2024/1689), применяемый поэтапно; официальный таймлайн указывает вступление в применение значимой части правил с 2 августа 2026 и отдельные этапы в 2025–2027. ³

Для управления AI-рисками базовые первоисточники, на которые логично опираться “по умолчанию”, — **NIST** ⁴ **AI RMF 1.0** и Playbook, плюс стандарт системы менеджмента AI **ISO 42001**. ⁵ ⁶

Критический вывод для соло-режима: ваш главный ограничитель — не написание кода, а **операционный налог** (интеграции, безопасность, наблюдаемость, воспроизводимость, регрессии, стоимость запусков). Поэтому план должен максимизировать (1) воспроизводимость, (2) контроль стоимости и рисков, (3) скорость цикла “запрос → staging”, а объём функциональности в ранних фазах — минимизировать. ⁷

Короткая таблица допущений (явно)

Тема	Базовое допущение (если вы не уточнили иначе)	Почему это разумно
Старт проекта	2026-02-20	Требование в задаче + совпадает с опорной дорожной картой в материалах
Команда	1 человек (1.0 FTE) + агенты как ускоритель	Вы прямо указали “в одного с помощью агентов”
Домен/ продукты	Домен не задан; “продукт” = deployable-артефакт (API-сервис как первый archetype)	Так определено в материалах, и это самый проверяемый MVP для фабрики
Окружения	dev + staging (prod позже)	Снижение риска; promotion только после gates
Регуляторный контекст	EU AI Act потенциально релевантен, GDPR потенциально релевантен	Платформа обрабатывает данные и может подпадать под требования по прозрачности/управлению ⁸
Поставщик LLM	API-модель на старте, с возможностью смены	Минимизация ops-труда; стоимость управляется бюджетами и метриками ⁹

Допущения и варианты масштаба

Я строю фабрику как **внутреннюю платформу**: “golden paths” + стандартизированная поставка + self-serve, но расширяю self-serve только после того, как базовый конвейер стабилен. Такая логика соответствует паттерну platform team / internal platform, а измеримость через delivery-метрики (DORA) — устойчивый способ не “утонуть” в красивой архитектуре. ¹⁰

Ниже — три реалистичных варианта для соло-разработчика. Это не “три разных проекта”, а один проект с разными целевыми уровнями зрелости.

Вариант	Объём (scope)	Целевой срок	Что считается “готово”	Что сознательно отложено
Small solo	Один archetype (API-сервис), один pipeline, базовые политики и аудит, deploy в staging	8–12 недель	3 последовательных “factory run” на одном commit SHA: запрос → репо → CI gates → deploy в staging + базовые дашборды	Multi-tenancy, полноценный портал, расширенная комплаенс-обязка

Вариант	Объём (scope)	Целевой срок	Что считается “готово”	Что сознательно отложено
Medium solo	2–3 archetype, воспроизводимые eval-ворота (agent + RAG), supply-chain gates (SBOM+подпись), GitOps promotion	6–12 месяцев	“Factory” как продукт: стабильные релизы фабрики, метрики cycle time/cost per run, rollback сценарии, минимум governance по AI RMF/ISO 42001 ¹¹	Enterprise-уровень требований “всё сразу”, гибрид/он-прем по умолчанию
Large solo	Multi-tenancy, self-serve портал/CLI, несколько окружений и доменов, расширенные контролы	12–18+ месяцев	Масштабирование потребления фабрики и формальные контрольные точки для риска/стоимости/качества	Для соло без поддержки — высокий риск провала сроков и качества

Ключевая практическая рекомендация: **выбирайте Small или Medium как целевую рамку**, а элементы Large делайте “как миграционный путь” (совместимые интерфейсы, версии, контракты), иначе вы платите операционный налог заранее.

Архитектура и стек

Архитектурный каркас

Целевой архитектурный принцип — разделение **deterministic control plane** и **intelligence plane**. В предоставленном документе это обозначено как главный приём превращения “агентов, пишущих код” в фабрику с воспроизводимостью, контролем и масштабированием.

Практически это означает:

- всё, что можно заранее формализовать (политики, последовательности операций, ретраи, идемпотентность, аудит), уходит в детерминированный workflow/оркестратор; ¹²
- агентам разрешены только строго типизированные действия через tool-calling/structured outputs, а side-effects исполняются отдельным executor-ом под контролем policy engine. ¹³

flowchart TB

```

subgraph DC[Control Plane: детерминированный контур]
  API[Factory API]
  WF[Durable workflow execution]
  PE[Policy Engine (OPA/Rego)]
  TR[Tool Registry (JSON Schema, versioned)]
  EX[Tool Executor: sandbox + idempotency + retries]
  AUD[(Audit log / event store)]
end

```

```

subgraph INT[Intelligence Plane: агенты/LLM]
  AR[Agent runtime]
  LLM[LLM API / serving]
  RAG[RAG: retrieve/rerank/context pack]
  EV[Evaluators: offline/online, trace grading]
end

subgraph DATA[Данные]
  SO[(Systems of record)]
  VDB[(Vector index)]
  OBJ[(Object storage)]
end

subgraph OBS[Наблюдаемость]
  OTel[OpenTelemetry SDK/Collector]
  MET[(Metrics)]
  LOG[(Logs)]
  TRC[(Traces)]
end

API --> WF --> PE
WF --> AR
AR --> TR --> EX --> SO
EX --> VDB
EX --> OBJ
AR --> RAG --> VDB
RAG --> LLM
AR --> LLM
EV --> WF

API --> OTel
WF --> OTel
AR --> OTel
EX --> OTel
OTel --> MET
OTel --> LOG
OTel --> TRC
WF --> AUD
EX --> AUD

```

Критика и рекомендации по четырём осям

Масштабируемость. Сильная сторона схемы — возможность масштабировать интеллект отдельно от контроля: агентных воркеров может быть много, но контрольный контур остаётся воспроизводимым и управляет side-effects через политики/аудит. ¹⁴

Соло-риск: преждевременная multi-tenancy/self-serve добавляет требования к изоляции, биллингу,

поддержке и тем самым существенно увеличивает операционный налог. Поэтому multi-tenancy — поздний milestone (Medium/Large).

Безопасность. Практическая база для агентных рисков — руководствоваться **OWASP** ¹⁵ **Top 10 for LLM Applications** (prompt injection, insecure output handling, excessive agency, model DoS/unbounded consumption и др.). ¹⁶

Для структурированного threat modeling полезно использовать taxonomy adversarial ML от **NIST** ⁴ (**NIST AI 100-2e2025**) и knowledge base **MITRE** ¹⁷ **ATLAS**. ¹⁸

Соло-рекомендация: считать tool executor “критическим периметром”, потому что именно он делает side-effects; все привилегированные tools должны быть (а) идемпотентны, (б) журналируемы, (в) ограничены allowlist + budgets. ¹⁹

Поддерживаемость. Ваш “вечный враг” — невоспроизводимость. Поэтому всё, что влияет на поведение и стоимость, нужно версионировать: archetypes, tool schemas, политики, версии моделей/маршрутизацию, индексы/эмбединги, eval-наборы, инфраструктуру. Это требование прямо сформулировано в предоставленном документе как принцип “артефакты важнее магии”. На практике это означает Git-версионирование + release tags + “eval baseline” как gate. ²⁰

Стоимость. Стоимость в агентных системах растёт “скачками”: (1) токены/инструменты, (2) неограниченные траектории, (3) ретраи, (4) рост индексов и логов. Поэтому cost governance (бюджеты на токены/итерации/tool calls/время) должен быть встроен как policy, а не как “финансовый отчёт потом”. ⁹

Варианты технологического стека для соло

Ниже — практичные “пакеты” (не единственные), выбранные по критерию: минимальная ops-сложность при сохранении архитектурных интерфейсов.

Компонент	Small solo (минимум ops)	Medium solo (production-ориентир)	Large solo (масштаб)
Политики	OPA как цель, сначала небольшой набор правил (allowlist+budgets) ²¹	OPA bundles/decision logs + расширение по risk tiers ²²	Политики по доменам/тенантам, централизованное управление
Наблюдаемость	OTel Collector + OTLP как стандарт передачи ²³	Полный “3 сигнала” + SLO/alerts	Multi-tenant observability + ретеншн/комплаенс
Supply chain	SBOM baseline по CISA + скан в CI ²⁴	SBOM + подпись/аттестации (Sigstore Cosign) ²⁵	Политики допуска артефактов (provenance-проверка), строгие требования

Компонент	Small solo (минимум ops)	Medium solo (production-ориентир)	Large solo (масштаб)
RAG storage	PostgreSQL + pgvector на старте ²⁶	миграция триггерно в Qdrant/Weaviate/Milvus ²⁷	распределённая vector infra + шардирование
Оркестрация	простой orchestrator (или только CI) для MVP; durable execution как следующий шаг	Durable workflows (Temporal/аналог) для pause/resume, ретраев, аудита ¹²	Несколько очередей/воркеров, versioning workflow, более строгие SLO
Agent framework	Agents SDK (если вы в экосистеме OpenAI ²⁸) + structured outputs + trace grading ²⁹	то же + расширенные eval-ворота (trace eval runs) ³⁰	multi-agent с изоляцией полномочий и утверждений

Дорожная карта, вехи и критерии успеха

Roadmap-поток “от запроса до промоушена”

```

flowchart TB
  RQ[Запрос: цель + ограничения] --> PLAN[Агент: план/задачи/артефакты  
(структурно)]
  PLAN --> GEN[Генерация репозитория archetype]
  GEN --> CI[CI: build + unit/integration]
  CI --> SEC[Security gates: SBOM+scan+policy]
  SEC --> EVAL[Eval gates: RAG/agent миссии + trace grading]
  EVAL --> STG[Deploy в staging (GitOps)]
  STG --> MON[Online checks: SLO + cost budgets + drift]
  MON --> DEC{Decision point: promote?}
  DEC -- нет --> RB[Rollback/Freeze + инцидент]
  DEC -- да --> PRD[Promote to prod]

```

Ключевой смысл: фабрика — это **конвейер с измеримыми воротами**, а не “агент, который что-то написал”. Ровно это рекомендуется в предоставленном документе как способ ежедневного прогресса.

Роли и FTE-оценка для соло

В материалах минимальная жизнеспособная орг-модель для фабрики описывается как 8–12 ролей на старт (часть совмещается).

В соло-режиме я превращаю это в “шляпы” (всё равно нужно делать те же виды работы, просто последовательно):

Шляпа	Средняя доля времени в Medium solo	Типовые результаты (deliverables)
Platform architect	15%	ADR/SDD, границы agentности, интерфейсы, миграционные триггеры
Workflow/durable execution	20%	ретраи, идемпотентность, компенсации; воспроизводимые run-ы ¹²
Agent/LLM инженер	20%	schemas, tool routing, budgets, trace grading/evals ³¹
RAG/data инженер	15%	ingestion, versioning индекса, качество retrieval ³²
SRE/наблюдаемость	15%	OTel traces/metrics/logs, SLO/alerts, runbooks ²³
AppSec/LLMSec	10%	OWASP LLM Top10 controls, supply chain gates, threat modeling ³³
Governance	5%	AI RMF/ISO 42001 минимальный контур, decision points, change-control ³⁴

Фазы, сроки и deliverables как чек-листы

Ниже — план, синхронизированный с 12-месячной опорной дорожной картой, зафиксированной в предоставленном документе (старт 2026-02-20).

Это план для **Medium solo**; Small — это “обрезать до первых 8–12 недель”, Large — “добавить мульти-тенантность и портал после стабилизации”.

Фаза инициации и рамок риска (2 недели, 2026-02-20 → 2026-03-05)

Deliverables: - [] PRD фабрики (цель, границы MVP, “definition of done”) — один документ, один источник истины

- [] Классы действий агента: разрешено/запрещено (особенно privileged actions)
- [] Data map: какие источники данных, где PII, как ретеншн и доступы
- [] Risk register v1 (10–15 рисков, владелец — вы)
- [] Decision points v1 (что может заставить менять стек/архитектуру)

Success criteria: - PRD покрывает минимум: один archetype, один “golden path”, staging-деплой, измеримые gates.

- Любой tool с side-effects категоризирован по risk tier и требует политики/approval. ³⁵

Фаза основания (4–8 недель, 2026-02-20 → 2026-04-17)

(совпадает с блоком “Основание” в Gantt: архитектура слоёв, OPA, observability baseline)

Deliverables: - [] SDD + ADR-набор (архитектурные решения: workflow engine, policy engine, storage, LLM provider)

- [] Policy engine “минимальный”: allowlist tools, budgets (токены/tool calls/время), запрет прямых side-effects

- [] OpenTelemetry базовый трейсинг “factory run” end-to-end + аудит tool calls
- [] Tool registry: JSON Schema для каждого инструмента, версия, owner, risk tier

Success criteria: - Каждый factory run даёт trace + audit-события, и по trace можно восстановить “что произошло” (observability как обязательная часть). ³⁶

- Политики отделены от кода и могут блокировать привилегированные действия (OPA как policy decision point). ³⁷

Фаза MVP фабрики (8-12 недель, 2026-03-15 → 2026-06-15)

(в Gantt: первый archetype, contracts+executor, RAG ingestion/pgvector)

Deliverables: - [] Archetype “API service”: репозиторий с минимальным сервисом, тестами, Docker/IaC, документацией

- [] Tool executor: sandbox + идиомпотентность + ретраи (для любых внешних side-effects)
- [] CI: unit/integration + минимальные security checks + сборка артефакта
- [] RAG ingestion (если нужен): Postgres+pgvector, версионирование индекса/чанкинга

Success criteria: - 3 подряд воспроизводимых прогона “цель → repo → CI → staging”, без ручного вмешательства кроме approval шагов.

- Индекс RAG можно откатить на версию N-1, сохранив воспроизводимость retrieval. ²⁶

Фаза качества и надёжности (3 месяца, 2026-04-15 → 2026-07-15)

(в Gantt: eval контур, integration durable engine Temporal/Argo)

Deliverables: - [] Offline eval gates: набор “миссий агента” + регрессионные кейсы (минимум 30-50)

- [] Trace grading и отчёт по регрессам (при изменении prompts/tools/policies) ¹⁴
- [] Durable execution (если вы берёте Temporal/аналог): ретраи activity, pause/resume, human-in-the-loop

Success criteria: - Любой релиз фабрики блокируется, если eval-метрики ухудшились сверх порога (регресс-ворота). ¹⁴

- Разделение workflow vs activity соблюдено: “непредсказуемое” (LLM/tool calls/HTTP) вынесено в activity; это согласуется с практикой durable execution. ³⁸

Фаза supply-chain и комплаенса (3-4 месяца, 2026-06-01 → 2026-09-30)

(в Gantt: SBOM+scan+sign, threat modeling, AI governance)

Deliverables: - [] SBOM как артефакт сборки (как минимум machine-processable поля по guidance CISA) ³⁹

- [] Сканирование уязвимостей (Trivy) в CI с порогами и исключениями “по правилам” ⁴⁰
- [] Подпись артефактов (Sigstore Cosign) и проверка подписи в deployment gate ⁴¹
- [] Threat modeling пакет: OWASP LLM Top10 мэппинг + NIST AML taxonomy + ATLAS как справочник техник ⁴²
- [] Минимальный governance-контур: AI RMF (Govern/Map/Measure/Manage) + ISO/IEC 42001 “как система менеджмента” ⁶

Success criteria: - Любой деплой-артефакт имеет SBOM и подпись; неподписанный/непроверенный артефакт не промоутируется. ⁴³

- High-risk изменения требуют явного approval и записи decision record (auditability). ⁴⁴

Фаза продуктивизации и масштабирования потребления (3–4 месяца, 2026-08-01 → 2026-12-15)

(в Gantt: GitOps CD, canary, SLO/cost budgets, 2–3 archetype, multi-tenancy/portal)

Deliverables: - [] GitOps CD (например, Argo CD): staging→prod promotion как PR в env-репозиторий

45

- [] Canary/поэтапное включение + SLO/cost budgets как критерии промоушена

- [] 2–3 дополнительных archetype (web/data pipeline)

- [] (Опционально) portal/CLI/self-serve

Success criteria: - Rollback занимает минуты: revert commit desired state → синхронизация окружения.

45

- Метрики throughput/instability (DORA) и фабричные метрики (cycle time, cost per run) демонстрируют устойчивый тренд улучшения. 10

Сводная таблица зависимостей

Зависимость	Почему блокирует	Как снизить риск
Секреты/ключи/доступы	Без этого нельзя безопасно делать CI/CD и tools	Сразу выбрать подход (минимум: секреты CI + запрет логирования) + ротация ключей при инциденте 46
Наблюдаемость	Без трасс/аудита нельзя расследовать и улучшать	OTel baseline в фазе основания 23
Политики	Без PEP/allowlist агенты становятся “суперпользователем”	OPA как policy decision point и budgets по умолчанию 21
Eval-контур	Без gates регрессии становятся нормой	Trace grading + регрессионные миссии 30
Supply chain	Без SBOM/подписи трудно доказать целостность	CISA SBOM + SLSA-ориентированная изоляция сборки + Cosign 47

Gantt-таймлайн

Ниже — Gantt, совпадающий по структуре и датам с опорной 12-месячной дорожной картой в предоставленном документе (старт 2026-02-20).

```
gantt
  title Product Factory: 12-месячная дорожная карта внедрения
  dateFormat YYYY-MM-DD

  section Основание
  Архитектура разделения слоёв + SDD-шаблон :a1, 2026-02-20, 30d
  Policy engine (OPA) + базовые бюджеты/allowlists :a2, 2026-03-01, 45d
  Observability baseline (OTel Collector + traces) :a3, 2026-03-01, 60d
```

section Фабрика MVP	
Первый archetype: "API service" end-to-end	:b1, 2026-03-15, 60d
Tool contracts + sandbox executor	:b2, 2026-04-01, 60d
RAG ingestion + pgvector index versioning	:b3, 2026-04-10, 75d
section Надёжность и качество	
Eval контур: RAGAs + agent missions + trace grading	:c1, 2026-04-15, 90d
Workflow/durable engine интеграция (Temporal/Argo)	:c2, 2026-05-15, 90d
section Supply chain и комплаенс	
SBOM (Syft) + scan (Trivy) + signing (cosign)	:d1, 2026-06-01, 90d
Threat modeling (NIST AML + MITRE ATLAS)	:d2, 2026-06-15, 75d
AI governance (NIST AI RMF + ISO 42001 контуры)	:d3, 2026-06-15, 120d
section Продуктивизация	
GitOps CD (Argo CD), canary, SLO/cost budgets	:e1, 2026-08-01, 90d
2-3 дополнительных archetype (web, data pipeline)	:e2, 2026-09-01, 120d
Multi-tenancy + portal/CLI для self-serve	:e3, 2026-10-01, 120d

Риски и меры управления

Реестр рисков

Оценка: вероятность (Low/Med/High), влияние (Low/Med/High). В соло-режиме я считаю High-impact риски “приоритетом по умолчанию”, потому что восстановление после инцидента съедает недели.

Риск	Вероятность	Влияние	Митигирующие меры (до)	План на случай сбоя (после)
Unbounded consumption / Model DoS (агенты бесконечно вызывают LLM/ tools)	High	High	Budgets в policy (токены, tool calls, wall-time), лимиты на gateway; мониторинг cost per run ⁴⁸	Авто-останова workflow по бюджету; аварийный режим “read-only agents”; анализ trace и блокировка паттерна ¹⁴
Prompt injection через RAG/внешние данные	Med	High	“Untrusted data never drives tools”: структурная экстракция только валидируемых полей; guardrails + approvals ⁴⁹	Отключить внешние источники; откат индекса; ротация ключей; пост-мортем

Риск	Вероятность	Влияние	Митигирующие меры (до)	План на случай сбоя (после)
Excessive agency (агент получает слишком много полномочий)	Med	High	Allowlist tools по risk tier; human approval для write-операций; строгие схемы tool calling ⁵⁰	“Kill switch”: отключить privileged tools; временно запретить auto-promotion
Неидемпотентные side-effects при ретраях	Med	High	Idempotency keys + upsert/unique constraints; разделение workflow (детерминизм) и activity (ошибки/ ретраи) ⁵¹	Cleanup workflow + восстановление desired state через GitOps revert; фиксы и тест-регресс
Supply-chain атаки/ компрометация зависимостей	Med	High	SBOM (CISA) + скан (Trivy) + подпись (Cosign) + SLSA-требования к сборке (изоляция/ без секретов) ⁵²	Откат на “последний подписанный хороший”; блок релизов; ускоренный патч
Утечки секретов в логах/трейсах	Med	High	Redaction + запрет логирования чувствительных полей; минимизация секретов; access control к observability ²³	Ротация секретов; аудит; обновление политики логирования
Регуляторные/ политические изменения	Med	Med/ High	Регуляторный watch; пересмотр risk tier на decision points; минимальный governance по AI RMF/ISO 42001 ⁵³	Переприоритизация roadmap; заморозка функций, попадающих в high-risk
Невозможность расследовать инциденты (нет аудита/трейсов)	Med	High	OTel baseline с первого end-to-end run; audit log для tool calls ⁵⁴	Stop rollout; приоритет №1 — восстановить наблюдаемость

Привязка рисков к первоисточникам контролей

- Классы угроз (prompt injection, insecure output handling, excessive agency, model DoS/unbounded consumption) систематизированы в OWASP Top 10 for LLM Applications. 55
- Таксономия атак/митигирующих мер для adversarial ML — NIST AI 100-2e2025. 56
- “Матрица” техник и практические кейсы для AI-систем — MITRE ATLAS (fact sheet). 57
- Для организационного управления рисками — AI RMF 1.0 и Playbook (Govern/Map/Measure/Manage). 58
- Для secure SDLC (включая GenAI-специфичные рекомендации) — NIST SSDF и профиль SP 800-218A. 59

Стоимость и бюджетные сценарии

Я разделяю оценку стоимости на: **(1) люди/время, (2) LLM-стоимость, (3) инфраструктура/наблюдаемость/данные, (4) стоимость риска (инциденты)**. В соло-режиме пункт (4) часто дороже всех остальных, поэтому бюджеты и gates — часть экономической модели, а не “про безопасность”. 60

Низкая детализация

Вариант	Трудозатраты (solo)	Денежная стоимость (характер)	Что сильнее всего влияет
Small	2–3 месяца	низкая/средняя	частота factory runs и LLM-токены 61
Medium	6–12 месяцев	средняя	наблюдаемость + eval-контур + supply chain + LLM 62
Large	12–18+ месяцев	высокая	multi-tenancy, комплаенс, эксплуатация

Средняя детализация (структура бюджета)

Статья	Как считать	Комментарий
LLM inference	токены_in/out × цена за 1M токенов	Цены зависят от модели; официальный прайс показывает порядок цен по моделям и cached input 61
Eval/trace grading	число прогонов eval × токены × цена	Trace grading требует хранения/анализа трасс и прогонов оценок 14
Observability	объём логов/трейсов/метрик × ретеншн	OTel/OTLP задают стандартизированный пайплайн; стоимость зависит от backend 23
Data/RAG	размер индекса + запросы + хранение	pgvector — дешёвый старт; миграция к vector DB при росте требований 32
Supply chain	“время на интеграцию” + хранение артефактов	SBOM/scan/sign — в основном инженерная интеграция; инструменты: Syft/Trivy/Cosign 63

Высокая детализация: параметрическая модель LLM-стоимости + примеры

Официальный прайс OpenAI ²⁸ задаёт цены за 1М токенов (input/cached input/output) для ряда моделей. ⁶¹
Это позволяет честно считать стоимость “фабричного прогона” без гадания про инфраструктуру.

Формула (упрощённо):

$$\text{LLM_cost_month} = \text{runs_per_month} * (\text{input_tokens}/1\text{e}6 * \text{price_in} + \text{output_tokens}/1\text{e}6 * \text{price_out})$$

(если используете cached input, добавьте долю cached-токенов по отдельной цене). ⁶¹

Нижe — **примерные** сценарии (это допущения о нагрузке; вы можете подставить свои числа).

Вариант	Прогонов фабрики в день	Input токенов на прогон	Output токенов на прогон	Модель	Оценка LLM-стоимости в месяц (30 дней)
Small	10	50k	10k	gpt-5-mini	≈ \$4.35 ⁶¹
Medium	50	120k	25k	gpt-5.1	≈ \$291.25 ⁶¹
Large	200	200k	40k	gpt-5.2	≈ \$2,760.00 ⁶¹

Пояснение расчёта (пример Medium):
runs/month = 50×30 = 1500; cost = 1500×(120k/1e6×\$1.25 + 25k/1e6×\$10) = 1500×(0.15 + 0.25) = \$600; но если часть токенов кэшируется (cached input), стоимость может быть ниже; реальная будет зависеть от структуры промптов/контекстов и кэширования. ⁶¹

Сценарии “дешевле/дороже” (без привязки к конкретному облаку): - Снизить стоимость обычно проще через (а) уменьшение токенов (контракты, компактные schemas, “не тащить всё в контекст”), (б) кэширование повторяемых контекстов, (в) более дешёвую модель для части шагов (например, gpt-5-mini для “well-defined” задач), чем через “оптимизацию инфраструктуры”. ⁶⁴
- Самохост модели обычно двигает стоимость из “переменной по токенам” в “постоянную по GPU/ops”; экономически это оправдано, когда есть стабильная высокая нагрузка или требования к суверенности данных — это отражено как типичный decision point и в предоставленных материалах. ⁶⁵

Эксплуатация, governance, change-control, rollout и коммуникации

KPI и мониторинг

Я использую два слоя KPI: delivery performance (DORA) и фабричные (агентные) метрики.

Delivery-KPI (DORA): throughput/instability и конкретные метрики (deployment frequency, lead time, change fail rate, failed deployment recovery time, deployment rework rate). DORA официально описывает и обновляет эволюцию метрик (включая добавление deployment rework rate в 2024). ¹⁰

Фабричные KPI: - Cycle time: “запрос → PR”, “PR → staging”, “staging → prod” (как в предоставленных материалах).

- Automation coverage по risk tier: доля шагов без участия человека, отдельно для low/med/high-risk (чтобы не расширять автономность вслепую).

- Quality gates pass rate: доля прогонов, прошедших тесты+security+eval. ⁶⁶

- Cost per run + incidents unbounded consumption. ⁶⁷

- RAG-качество (если применимо): метрики retrieval/faithfulness по вашим eval наборам (в материалах это оформлено как отдельный eval-контур).

Наблюдаемость: базовый стандарт — OpenTelemetry + OTLP: Collector описан как vendor-agnostic компонент для приёма/обработки/экспорта телеметрии, а OTLP — стабильный протокол доставки трейсов/метрик/логов. ²³

Governance и decision points

Я выстраиваю governance как “лёгкий каркас”, основанный на AI RMF, а не как бюрократию: AI RMF задаёт функции Govern/Map/Measure/Manage и предполагает, что организация выбирает объём внедрения по контексту и риску. ⁵⁸

ISO/IEC 42001 добавляет управленческую дисциплину AIMS (политики, процедуры, PDCA-цикл) как стандарт системы менеджмента. ⁶⁸

Decision points, которые стоит формализовать как ADR-триггеры (с измеримыми порогами): - API-LLM → self-host: триггеры — cost per run, требования к суверенности/персональным данным, латентность, контроль версий. ⁶⁹

- pgvector → выделенная vector DB: триггеры — рост индекса, требования к фильтрации/строгому режиму, multi-tenant, SLA по латентности. ⁷⁰

- Расширение инструментов агента: каждый новый tool с side-effects требует угроз-анализа по OWASP/NIST/ATLAS и политики доступа/бюджетов. ⁷¹

Change-control процесс

В соло-режиме change-control нужен не “для отчётности”, а чтобы агенты не ускоряли хаос.

Классы изменений (risk-based): - Low: документация, refactor без изменения контрактов/policies.

- Medium: новые archetype, изменения CI, новые источники RAG.

- High: новый tool с side-effects, изменения политик, изменения секретов, расширение агентности/автопромоушена.

Правила ворот (gates): - Medium: обязателен зелёный CI + security scan + минимальный eval. ⁷²

- High: ручной approval + threat-мэппинг (OWASP/NIST/ATLAS) + обязательный аудит + подпись артефактов. ⁷³

Rollout и rollback

Rollout: staging → онлайн-проверки → promote. Это согласуется с подходом “trace grading + онлайн-метрики” как решение о продвижении. 14

GitOps CD: Argo CD автоматическая синхронизация делает деплой через commit в Git; документация подчёркивает семантику autosync и нюанс, что rollback нельзя выполнить для приложения с включённым automated sync (важно учесть в вашей процедуре). 45

Практический rollback-план (минимум): - код/конфиги: revert commit desired state → sync;
- артефакты: откат на последний подписанный и верифицированный (Cosign verify) образ; 74
- данные: только backward-compatible миграции (expand/contract), иначе вы теряете “безболезненный” rollback.

План коммуникации со стейкхолдерами

Даже если вы “соло”, вам почти всегда нужен хотя бы один стейкхолдер (спонсор/потребитель/безопасность). Я бы вёл коммуникацию через артефакты и метрики:

Аудитория	Формат	Частота	Что показываю
Спонсор/ руководитель	15-мин демонстрация “запрос → staging” + 1-страничный статус	еженедельно	cycle time, cost per run, блокеры, решения decision points 7
Безопасность/ AppSec	обзор risk register + результаты supply chain gates	раз в 2–4 недели	OWASP LLM Top10 мэппинг, SBOM/scan/sign статус 75
Потребители (разработчики)	quickstart + пример archetype	по релизу	golden path, ограничения, шаблонные решения
Операции/SRE	runbooks + SLO	раз в месяц	алерты, ретеншн, инциденты, MTTR 76

Инструменты и шаблоны

Рекомендуемый tooling-набор для соло

- Трекинг задач: **GitHub 77 Issues/Projects + строгие labels по risk tier. 78
- CI: GitHub Actions как единая точка для build/test/security/eval. 78
- Policy as code: OPA/Rego. 21
- Observability: OpenTelemetry + OTLP, минимально — трейсинг фабричного прогона и аудит tool calls. 23
- GitOps CD: Argo CD (или эквивалент). 45
- SBOM/scan/sign: Syft + Trivy + Cosign (Sigstore). 63
- Agent dev: structured outputs + tool calling + trace grading/Agents SDK (если вы в экосистеме OpenAI). 79

Шаблон ADR (полностью заполненный пример)

ADR-0001: Выбор движка оркестрации для фабрики

Дата: 2026-02-20

Статус: accepted

Контекст

Я строю Product Factory как соло-разработчик с агентами. Мне нужна воспроизводимая оркестрация, где:

- наблюдаемая история выполнения (для аудита и отладки),
- ретраи для внешних операций,
- возможность human approval,
- возможность паузы/возобновления длинных прогонов.

Драйверы

- Надёжность и воспроизводимость
- Управляемая агентность (agents ≠ side-effects)
- Низкий операционный налог (solo)
- Наблюдаемость и аудит

Рассмотренные варианты

- A) Temporal / durable workflows (workflows детерминированы; activity для недетерминированного)
- B) Argo Workflows (K8s-native DAG/steps; хорошо для batch)
- C) Без workflow engine на старте (только CI steps), затем миграция

Решение

Принимаю C как старт на 8-12 недель для MVP фабрики, затем перехожу к A (durable workflows) при достижении:

- 50+ прогонов фабрики в день или
- потребности в pause/resume и human approval в прод-контуре.

Обоснование

- Для MVP важна скорость и минимальный ops.
-

Для production агентных пайплайнов нужна durable execution семантика ретраев и истории.

Последствия

Плюсы:

- Быстрое достижение end-to-end результата на MVP
- Чёткий план миграции к durable execution

Минусы:

- В MVP сложнее делать сложные компенсации и паузы
- Переход потребует выделенного времени на интеграцию

Триггеры пересмотра

- Инциденты из-за ретраев/дублирования side-effects
- Появление требований “пауза/возобновление” и human approval
- Рост стоимости инцидентов выше стоимости внедрения durable engine

PR-шаблон (без “пустых” плейсхолдеров)

Цель изменения

Кратко: что улучшено и зачем.

Класс риска

Выберите один вариант и удалите остальные строки:

- risk: low
- risk: medium
- risk: high

Изменения затрагивают

- contracts (tool schemas): да/нет
- policies (OPA): да/нет
- tools с side-effects: да/нет
- eval наборы/гейты: да/нет
- CI/CD: да/нет
- секреты/доступы: да/нет

Gates

- ☐ Unit tests зелёные
- ☐ Integration tests зелёные
- ☐ Security scan (Trivy) зелёный или есть задокументированные исключения
- ☐ SBOM (Syft) сгенерирован
- ☐ Подпись артефакта выполнена (Cosign) и верификация проходит
- ☐ Offline eval (trace grading / миссии агента) не регрессирует

План отката

- Git revert commit SHA
- Откат образа на предыдущий подписанный digest
- Для данных: миграции backward-compatible (expand/contract)

Наблюдаемость

- ☐ Трейсы factory run доступны
- ☐ Audit log tool calls доступен

Risk register (шаблон + 3 заполненных строки)

```
# Risk Register (v1)

| ID | Риск | Вероятность | Влияние | Владелец | Митигирующие меры | План при инциденте | Метрика/сигнал |
|---|---|---|---|---|---|---|---|
| R-001 | Unbounded consumption / Model DoS | High | High | Solo | budgets: tokens/tool-calls/time + allowlist | kill workflow + disable privileged tools | cost per run, tool calls/run |
| R-002 | Prompt injection через RAG | Med | High | Solo | structured extraction + approvals for write tools | отключить внешние источники + откат индекса | suspicious tool calls |
| R-003 | Supply-chain компрометация | Med | High | Solo | SBOM+scan+sign+verify in gates | rollback на last signed | scan findings, signature verify |
```

Список первичных источников (как ссылки, пригодные для внутренней базы знаний)

NIST AI RMF 1.0 (NIST AI 100-1): <https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>

NIST AI RMF Playbook: <https://airc.nist.gov/airmf-resources/playbook/>

ISO/IEC 42001: <https://www.iso.org/standard/42001>

EU AI Act (Regulation (EU) 2024/1689): <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng>

EU AI Act implementation timeline: <https://ai-act-service-desk.ec.europa.eu/en/ai-act/eu-ai-act-implementation-timeline>

GDPR (Regulation (EU) 2016/679): <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng>

OWASP Top 10 for LLM Applications 2025 (PDF): <https://owasp.org/www-project-top-10-for-large-language-model-applications/assets/PDF/OWASP-Top-10-for-LLMs-v2025.pdf>

CISA 2025 Minimum Elements for SBOM (PDF): https://www.cisa.gov/sites/default/files/2025-08/2025_CISA_SBOM_Minimum_Elements.pdf

SLSA spec and requirements: <https://slsa.dev/spec/v1.0/requirements>

OpenTelemetry Collector: <https://opentelemetry.io/docs/collector/>

OTLP spec: <https://opentelemetry.io/docs/specs/otlp/>

OPA docs: <https://www.openpolicyagent.org/docs/latest>

Argo CD autosync semantics: https://argo-cd.readthedocs.io/en/latest/user-guide/auto_sync/

Syft: <https://github.com/anchore/syft>

Trivy vulnerability scanning: <https://trivy.dev/docs>

Sigstore Cosign quickstart: <https://docs.sigstore.dev/quickstart/quickstart-cosign/>

OpenAI Pricing: <https://platform.openai.com/docs/pricing/>

OpenAI Agents SDK: <https://platform.openai.com/docs/guides/agents-sdk/>
OpenAI Structured Outputs: <https://platform.openai.com/docs/guides/structured-outputs>
OpenAI Function calling: <https://platform.openai.com/docs/guides/function-calling/>
OpenAI Trace grading: <https://platform.openai.com/docs/guides/trace-grading>
DORA metrics guide: <https://dora.dev/guides/dora-metrics/>

European Union ⁸⁰ CISA ⁸¹ Cloud Native Computing Foundation ⁸²

¹ ¹³ ³¹ **Function calling - OpenAI API**

https://platform.openai.com/docs/guides/function-calling/how-do-i-ensure-the-model-calls-the-correct-function?utm_source=chatgpt.com

² ¹⁹ ²¹ ³⁷ ⁴⁴ **Open Policy Agent (OPA) | Open Policy Agent**

https://www.openpolicyagent.org/docs/latest?utm_source=chatgpt.com

³ **Regulation - EU - 2024/1689 - CS - EUR-Lex**

https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng?utm_source=chatgpt.com

⁴ ¹⁴ ²⁰ ³⁰ ⁶⁶ **Trace grading | OpenAI API**

https://platform.openai.com/docs/guides/trace-grading?utm_source=chatgpt.com

⁵ ⁷ ¹⁰ ²⁸ ⁷⁶ **DORA | DORA's software delivery performance metrics**

https://dora.dev/guides/dora-metrics/?utm_source=chatgpt.com

⁶ ¹¹ ³⁴ ⁵⁸ **NIST AI 100-1**

https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf?utm_source=chatgpt.com

⁸ ⁵³ **Timeline for the Implementation of the EU AI Act | AI Act Service Desk**

https://ai-act-service-desk.ec.europa.eu/en/ai-act/eu-ai-act-implementation-timeline?utm_source=chatgpt.com

⁹ ⁶⁰ ⁶¹ ⁶⁴ ⁶⁷ ⁶⁹ ⁸⁰ **Pricing | OpenAI API**

https://platform.openai.com/docs/pricing/?utm_source=chatgpt.com

¹² **Durable Execution Solutions | Temporal**

https://temporal.io/?utm_source=chatgpt.com

¹⁵ ⁶³ **GitHub - anchore/syft: CLI tool and library for generating a Software Bill of Materials from container images and filesystems**

https://github.com/anchore/syft?utm_source=chatgpt.com

¹⁶ **OWASP Top 10 for Large Language Model Applications | OWASP Foundation**

https://owasp.org/www-project-top-10-for-large-language-model-applications/?utm_source=chatgpt.com

¹⁷ ³³ ⁴² ⁴⁸ ⁵⁰ ⁵⁵ ⁷¹ ⁷³ ⁷⁵ ⁷⁷ ⁸¹ **OWASP Top 10 for**

https://owasp.org/www-project-top-10-for-large-language-model-applications/assets/PDF/OWASP-Top-10-for-LLMs-v2025.pdf?utm_source=chatgpt.com

¹⁸ ⁵⁶ **AI 100-2 E2025, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations | CSRC**

https://csrc.nist.gov/pubs/ai/100/2/e2025/final?utm_source=chatgpt.com

22 **Discovery | Open Policy Agent**

https://www.openpolicyagent.org/docs/management-discovery?utm_source=chatgpt.com

23 36 54 62 **Collector | OpenTelemetry**

https://opentelemetry.io/docs/collector/?utm_source=chatgpt.com

24 39 **2025 Minimum Elements for a Software Bill of Materials (SBOM) | CISA**

https://www.cisa.gov/resources-tools/resources/2025-minimum-elements-software-bill-materials-sbom?utm_source=chatgpt.com

25 41 **Sigstore Quickstart with Cosign - Sigstore**

https://docs.sigstore.dev/quickstart/quickstart-cosign/?utm_source=chatgpt.com

26 32 70 **GitHub - pgvector/pgvector: Open-source vector similarity search for Postgres**

https://github.com/pgvector/pgvector?utm_source=chatgpt.com

27 **Overview - Qdrant**

https://qdrant.tech/documentation/overview/?utm_source=chatgpt.com

29 **Agents SDK | OpenAI API**

https://platform.openai.com/docs/guides/agents-sdk?utm_source=chatgpt.com

35 46 49 **Safety in building agents | OpenAI API**

https://platform.openai.com/docs/guides/agent-builder-safety?utm_source=chatgpt.com

38 51 **102 20240906a**

https://learn.temporal.io/assets/files/temporal-102-with-go-replay2025-37d6b2a2393d1e6e2523f55ee0aa9f70.pdf?utm_source=chatgpt.com

40 72 **Vulnerability - Trivy**

https://trivy.dev/docs/v0.50/scanner/vulnerability/?utm_source=chatgpt.com

43 47 52 **TLP:CLEAR 2025 Minimum Elements for a Software**

https://www.cisa.gov/sites/default/files/2025-08/2025_CISA_SBOM_Minimum_Elements.pdf?utm_source=chatgpt.com

45 **Automated Sync Policy - Argo CD - Declarative GitOps CD for Kubernetes**

https://argo-cd.readthedocs.io/en/latest/user-guide/auto_sync/?utm_source=chatgpt.com

57 **A COLLABORATION ACROSS INDUSTRY, ACADEMIA, AND GOVERNMENT |**

https://atlas.mitre.org/pdf-files/MITRE_ATLAS_Fact_Sheet.pdf?utm_source=chatgpt.com

59 82 **Secure Software Development Framework | CSRC**

https://csrc.nist.gov/projects/ssdf?utm_source=chatgpt.com

65 **Playbook - AIRC**

https://airc.nist.gov/airmf-resources/playbook/?utm_source=chatgpt.com

68 **ISO/IEC 42001:2023 - AI management systems**

https://www.iso.org/standard/42001?utm_source=chatgpt.com

74 **Verifying Signatures - Sigstore**

https://docs.sigstore.dev/cosign/verifying/verify/?utm_source=chatgpt.com

78 **GitHub Actions documentation - GitHub Docs**

https://docs.github.com/actions?utm_source=chatgpt.com

79 **Structured model outputs | OpenAI API**

https://platform.openai.com/docs/guides/structured-outputs?api-mode=chat&utm_source=chatgpt.com